

INFORME DE PENTESTING

=====

Usuario TryHackMe:
santilllirocio20

Repositorio:
TP_TryHackMe

Branch:
santilli-rocio

1. DATOS GENERALES

=====

Tipo de actividad:
Pentesting en entorno controlado de TryHackMe.

Plataforma:
TryHackMe.

Laboratorios realizados:
- Pentesting Fundamentals
- Basic Pentesting
- Vulniversity

Alcance:
La actividad se realizó exclusivamente sobre los objetivos asignados por TryHackMe dentro de los laboratorios correspondientes.

2. PRE-PENTESTING

=====

La actividad se realizó en un entorno controlado y autorizado con fines académicos.

Antes de comenzar se verificó el acceso a la plataforma TryHackMe, la conectividad de Kali Linux y el funcionamiento de la conexión VPN.

Metodología utilizada:

1. Reconocimiento
2. Escaneo
3. Enumeración
4. Explotación
5. Post-explotación
6. Documentación de resultados

3. RECONOCIMIENTO

=====

Se verificó la conectividad de Kali Linux y el funcionamiento de la VPN de TryHackMe.

Usuario de TryHackMe:
santilllirocio20

La conexión VPN permitió acceder a los objetivos de los laboratorios.

Objetivos utilizados:

Basic Pentesting:
10.67.165.224

Vulniversity:
10.66.132.228

4. HALLAZGO BP-01 - SERVICIOS EXPUESTOS =====

ID:
BP-01

Fase:
Escaneo y enumeración.

Objetivo:
10.67.165.224

Herramienta:
Nmap.

Comando principal:

nmap -sC -sV 10.67.165.224

Se identificaron diferentes servicios expuestos, entre ellos SSH, HTTP, SMB, AJP y Apache Tomcat.

La información obtenida mediante el escaneo permitió continuar con la enumeración del objetivo.

5. HALLAZGO BP-02 - INFORMACIÓN EXPUESTA EN EL SERVIDOR WEB =====

ID:
BP-02

Fase:
Enumeración.

Objetivo:
10.67.165.224

Herramientas:
Gobuster y curl.

Se realizó enumeración de directorios mediante Gobuster.

Se identificó el directorio:

/development

Posteriormente se consultaron recursos disponibles mediante curl.

Entre la información obtenida se encontraron los archivos:

dev.txt
j.txt

El contenido de estos recursos proporcionó información adicional sobre el entorno y permitió continuar con las pruebas del laboratorio.

Impacto:

La exposición de información sobre servicios, configuraciones o componentes del sistema puede facilitar la identificación de posibles vectores de ataque.

6. HALLAZGO BP-03 - ACCESO MEDIANTE CREDENCIALES

=====

ID:
BP-03

Fase:
Explotación.

Objetivo:
10.67.165.224

Durante la práctica Basic Pentesting se realizaron pruebas sobre el servicio SSH utilizando las credenciales obtenidas durante la enumeración.

Se logró acceder al sistema mediante SSH con el usuario correspondiente.

Posteriormente se realizó enumeración de usuarios y archivos del sistema.

Evidencias relacionadas:

evidencias/explotacion/32. ssh_jan_password.png
evidencias/explotacion/34. usuario_jan.png
evidencias/explotacion/35. acceso_ssh_jan.png

7. HALLAZGO BP-04 - EXPOSICIÓN DE CLAVE PRIVADA

=====

ID:
BP-04

Fase:
Post-explotación.

Objetivo:
10.67.165.224

Durante la enumeración del sistema se localizó una clave privada perteneciente al usuario Kay.

Posteriormente se realizaron pruebas controladas para determinar si la clave permitía obtener acceso al usuario.

Se logró acceder al usuario correspondiente.

Evidencias:

evidencias/explotacion/40. clave_privada_kay.png
evidencias/explotacion/41. clave_kay_crackeada.png
evidencias/explotacion/42. acceso_usuario_kay.png

8. HALLAZGO VULN-01 - CARGA DE ARCHIVOS =====

ID:
VULN-01

Fase:
Escaneo y explotación.

Objetivo:
10.66.132.228

Puerto:
3333/TCP

Herramientas:
Nmap y Gobuster.

Durante la enumeración del servicio web se identificó el recurso:

/internal

Dentro del recurso se encontró un formulario de carga de archivos.

También se identificó:

/internal/uploads/

La aplicación rechazó determinadas extensiones de archivo, pero permitió la carga utilizando una extensión alternativa.

Esto permitió comprobar una debilidad en la validación de extensiones.

Evidencias:

evidencias/escaneo/53. vulniversity_internal.png
evidencias/escaneo/54. vulniversity_formulario.png
evidencias/explotacion/55. vulniversity_uploads.png

9. HALLAZGO VULN-02 - EJECUCIÓN DE ARCHIVO SUBIDO =====

ID:
VULN-02

Fase:
Explotación.

Objetivo:
10.66.132.228

Se realizó una prueba controlada de carga utilizando un archivo con extensión .phtml.

El servidor permitió la carga del archivo.

Posteriormente, al acceder al archivo mediante el navegador, se obtuvo la respuesta:

VULNIVERSITY_TEST

Esto demostró que el archivo cargado podía ser interpretado por el servidor.

Evidencias:

evidencias/explotacion/56. vulniversity_upload_prueba.png
evidencias/explotacion/57. vulniversity_extension_phtml.png
evidencias/explotacion/58. vulniversity_phtml_ejecucion.png

10. HALLAZGO VULN-03 - OBTENCIÓN DE SHELL =====

ID:
VULN-03

Fase:
Explotación.

Objetivo:
10.66.132.228

A partir de la posibilidad de ejecutar un archivo cargado se obtuvo una shell inversa dentro del laboratorio.

Se utilizó Netcat como listener:

```
nc -lvnp 4444
```

El acceso obtenido correspondió al usuario:

www-data

La identidad se verificó mediante:

```
whoami  
id
```

También se consultó información del sistema mediante:

```
pwd  
uname -a  
hostname
```

Evidencia:

evidencias/explotacion/59. vulniversity_shell_subida.png
evidencias/explotacion/60. vulniversity_acceso_www-data.png

11. HALLAZGO VULN-04 - ESCALADA DE PRIVILEGIOS

=====

ID:

VULN-04

Fase:

Post-explotación.

Objetivo:

10.66.132.228

Una vez obtenido acceso como www-data se realizó una búsqueda de archivos con permisos SUID.

Durante la enumeración se identificó:

/bin/systemctl

El binario presentaba permisos SUID y permitió utilizarlo como vector de escalada de privilegios dentro del laboratorio.

Evidencia:

evidencias/explotacion/63. vulniversity_suid.png

12. ESCALADA MEDIANTE SYSTEMCTL

=====

Se creó un servicio temporal:

/tmp/root.service

Posteriormente se vinculó el servicio mediante:

/bin/systemctl link /tmp/root.service

Y se inició mediante:

/bin/systemctl start root.service

El procedimiento permitió generar un binario Bash con permisos SUID:

/tmp/rootbash

La elevación de privilegios se comprobó mediante:

/tmp/rootbash -p -c 'whoami'

Resultado:

root

También se verificó mediante:

id

obteniendo euid=0.

Evidencias:

evidencias/explotacion/64. vulniversity_systemctl.png
evidencias/explotacion/65. vulniversity_servicio_root.png
evidencias/post/67. vulniversity_root_access.png
evidencias/post/68. vulniversity_sistema_root.png

13. FLAGS OBTENIDAS

=====

Flag de usuario de Vulniversity:

8bd7992fbe8a6ad22a63361004cfcedb

SHA-256:

d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956

Flag de root de Vulniversity:

a58ff8579f0a9270368d33a9966c7fd5

SHA-256:

cfbc740435ad60030304880e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

14. IMPACTO

=====

Los hallazgos encontrados permitieron demostrar diferentes riesgos de seguridad dentro de los laboratorios.

Entre ellos:

- Exposición de información de servicios.
- Exposición de información en recursos web.
- Uso de credenciales obtenidas durante la enumeración.
- Exposición de claves privadas.
- Validación insuficiente de extensiones de archivos.
- Ejecución de archivos cargados.
- Obtención de acceso remoto como usuario del servidor web.
- Escalada de privilegios hasta root.

En un entorno real, estas condiciones podrían comprometer la confidencialidad, integridad y disponibilidad de la información.

15. RECOMENDACIONES

=====

Se recomienda:

- Mantener únicamente los servicios necesarios expuestos.
- Actualizar regularmente los servicios y aplicaciones.
- Evitar la exposición de información sensible en recursos web.
- Proteger correctamente las claves privadas.
- Implementar una validación estricta del tipo y contenido de archivos subidos.
- Evitar la ejecución de archivos cargados por usuarios.
- Revisar periódicamente los permisos SUID.
- Aplicar el principio de mínimo privilegio.
- Revisar las configuraciones de sudo y servicios del sistema.
- Registrar y monitorear accesos y actividades sospechosas.

16. PROTOCOLO DE CONTINGENCIA

=====

Escenario de falla:

Durante una evaluación de seguridad podría producirse una interrupción del servicio, pérdida de conectividad o modificación accidental de recursos del laboratorio.

Impacto:

La indisponibilidad del servicio podría impedir continuar con las pruebas y afectar temporalmente el entorno utilizado.

Activación:

Ante una falla se deben detener las pruebas y verificar el estado del objetivo.

Contención:

No continuar con acciones de explotación hasta determinar la causa de la falla.

Recuperación:

Restaurar el laboratorio mediante el mecanismo de reinicio o recuperación proporcionado por TryHackMe.

Comunicación:

Registrar el incidente y comunicarlo al responsable de la actividad si corresponde.

Post-mortem:

Documentar la causa, las acciones realizadas y las medidas necesarias para evitar una repetición.

RT0:

El tiempo de recuperación debe ser el mínimo necesario para restablecer

el laboratorio y continuar con la actividad.

RPO:

Se prioriza conservar las evidencias y registros generados antes del incidente.

17. EVIDENCIAS

=====

Las evidencias se encuentran organizadas según las fases del pentesting:

evidencias/reconocimiento/
evidencias/escaneo/
evidencias/explotacion/
evidencias/post/

Las capturas corresponden al proceso realizado durante los laboratorios de TryHackMe.

18. HASHES

=====

Los valores SHA-256 de las flags se encuentran documentados en:

reportes/ hashes_flags.txt

También se incluye evidencia gráfica de los hashes obtenidos.

19. DECLARACIÓN ÉTICA

=====

La actividad fue realizada exclusivamente en los laboratorios controlados y autorizados de TryHackMe, con fines académicos.

No se realizaron pruebas sobre sistemas externos al alcance definido.

20. CONCLUSIÓN

=====

La práctica permitió aplicar un proceso completo de pentesting, incluyendo reconocimiento, escaneo, enumeración, explotación y post-explotación.

Se logró documentar el acceso a los objetivos, las vulnerabilidades identificadas, las evidencias obtenidas y las medidas de mitigación correspondientes.

Los laboratorios Pentesting Fundamentals, Basic Pentesting y Vulnversity fueron completados satisfactoriamente.

21. MATRIZ DE CLASIFICACIÓN DE HALLAZGOS

=====

BP-01 - Servicios expuestos

Categoría:

CWE-200 - Exposición de información sensible.

OWASP:

A05 - Security Misconfiguration.

CVE:

No aplica.

CVSS estimado:

Medio.

Impacto CIA:

Confidencialidad.

Salvaguarda:

Reducir la exposición de servicios y mantener únicamente aquellos necesarios para la operación. Mantener los servicios actualizados.

Riesgo residual:

Bajo.

BP-02 - Información expuesta en recursos web

Categoría:

CWE-200 - Exposición de información sensible.

OWASP:

A05 - Security Misconfiguration.

CVE:

No aplica.

CVSS estimado:

Medio.

Impacto CIA:

Confidencialidad.

Salvaguarda:

Evitar publicar información técnica innecesaria y restringir el acceso a archivos de configuración, documentación interna y recursos de desarrollo.

Riesgo residual:

Bajo.

BP-03 - Acceso mediante credenciales

Categoría:

CWE-521 - Requisitos débiles de contraseñas.

OWASP:

A07 - Identification and Authentication Failures.

CVE:

No aplica.

CVSS estimado:

Alto.

Impacto CIA:

Confidencialidad e Integridad.

Salvaguarda:

Utilizar contraseñas robustas, evitar credenciales predecibles y aplicar políticas de autenticación adecuadas.

Riesgo residual:

Medio.

BP-04 - Exposición de clave privada

Categoría:

CWE-321 - Uso de claves criptográficas codificadas.

OWASP:

A07 - Identification and Authentication Failures.

CVE:

No aplica.

CVSS estimado:

Alto.

Impacto CIA:

Confidencialidad e Integridad.

Salvaguarda:

Proteger las claves privadas mediante permisos restrictivos, evitar su exposición en directorios accesibles y utilizar mecanismos seguros de gestión de claves.

Riesgo residual:

Medio.

VULN-01 - Carga de archivos

Categoría:

CWE-434 - Carga de archivos de tipo peligroso sin restricciones.

OWASP:

A05 - Security Misconfiguration.

CVE:

No aplica.

CVSS estimado:

Alto.

Impacto CIA:

Confidencialidad e Integridad.

Salvaguarda:

Validar extensión, tipo MIME y contenido real de los archivos. Los archivos cargados por usuarios no deben poder ejecutarse como código.

Riesgo residual:

Medio.

VULN-02 - Ejecución de archivo subido

Categoría:

CWE-434 - Carga de archivos de tipo peligroso.

OWASP:

A03 - Injection.

CVE:

No aplica.

CVSS estimado:

Crítico.

Impacto CIA:

Confidencialidad, Integridad y Disponibilidad.

Salvaguarda:

Impedir la ejecución de archivos cargados por usuarios y almacenar las cargas en ubicaciones sin permisos de ejecución.

Riesgo residual:

Medio.

VULN-03 - Obtención de shell

Categoría:

CWE-78 - Improper Neutralization of Special Elements used in an OS Command.

OWASP:

A03 - Injection.

CVE:

No aplica.

CVSS estimado:

Crítico.

Impacto CIA:

Confidencialidad, Integridad y Disponibilidad.

Salvaguarda:

Impedir la ejecución de código arbitrario, aplicar mínimo privilegio, validar entradas y monitorear procesos y conexiones salientes.

Riesgo residual:

Medio.

VULN-04 - Escalada de privilegios mediante systemctl

Categoría:

CWE-269 - Improper Privilege Management.

OWASP:

A05 - Security Misconfiguration.

CVE:

No aplica.

CVSS estimado:

Crítico.

Impacto CIA:

Confidencialidad, Integridad y Disponibilidad.

Salvaguarda:

Eliminar permisos SUID innecesarios, revisar periódicamente los binarios con privilegios especiales y aplicar mínimo privilegio.

Riesgo residual:

Medio.

22. RESUMEN EJECUTIVO

=====

La evaluación de seguridad permitió analizar tres laboratorios de TryHackMe: Pentesting Fundamentals, Basic Pentesting y Vulniversity.

Durante las prácticas se aplicaron las etapas de reconocimiento, escaneo, enumeración, explotación y post-explotación.

En Basic Pentesting se identificaron servicios expuestos, información disponible en recursos web, acceso mediante credenciales y exposición de una clave privada.

En Vulniversity se identificó una debilidad en la validación de archivos subidos, que permitió demostrar la ejecución de un archivo y obtener acceso al servidor como www-data. Posteriormente se identificó un binario systemctl con permisos SUID que permitió demostrar una escalada de privilegios hasta root.

Los resultados muestran la importancia de aplicar configuraciones seguras, controles de acceso, validación de archivos, protección de credenciales y principio de mínimo privilegio.

23. MARCO METODOLÓGICO

=====

La evaluación se realizó siguiendo una metodología de pentesting basada en las siguientes etapas:

Reconocimiento:

Identificación del entorno, conectividad y objetivos.

Escaneo:

Identificación de puertos, servicios y versiones.

Enumeración:

Obtención de información adicional sobre servicios y recursos disponibles.

Explotación:

Validación controlada de las vulnerabilidades identificadas.

Post-explotación:

Verificación del nivel de acceso obtenido, información del sistema y posibilidad de escalada de privilegios.

Documentación:

Registro de comandos, resultados, evidencias y recomendaciones.

El trabajo se desarrolló exclusivamente sobre los laboratorios autorizados de TryHackMe.

24. TRAZABILIDAD DE EVIDENCIAS

=====

Las evidencias fueron organizadas de acuerdo con las fases de la actividad.

Reconocimiento:

evidencias/reconocimiento/

Escaneo:

evidencias/escaneo/

Explotación:

evidencias/explotacion/

Post-explotación:

evidencias/post/

Los archivos de bitácora se encuentran en:

bitacora/

Los hashes SHA-256 de las flags se encuentran en:

reportes/hashes_flags.txt

La declaración ética se encuentra en:

reportes/declaracion_etica.txt